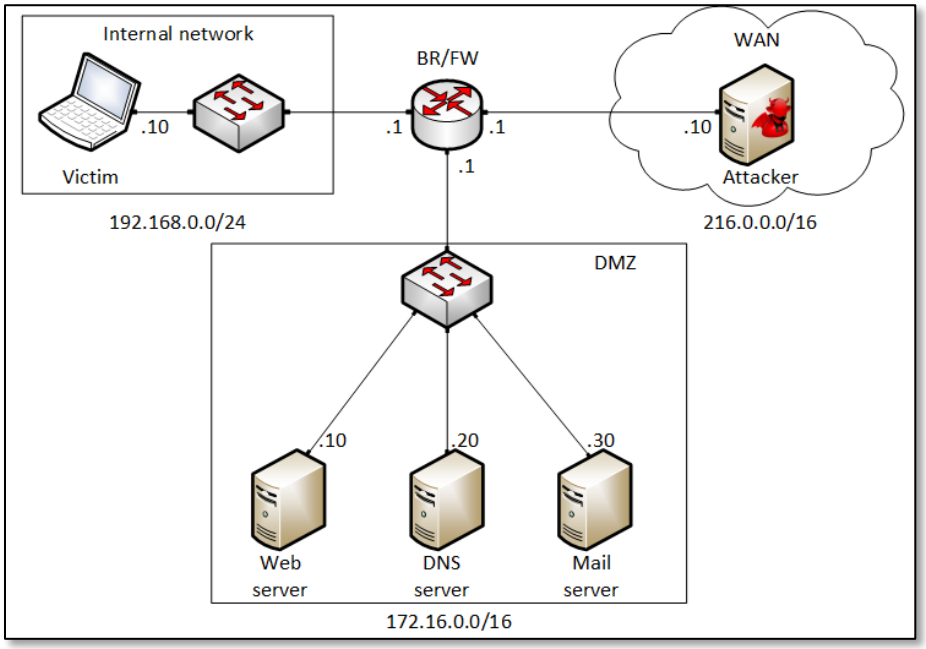
ITEC 493: IT Security for Managers
Fall 2025
Final Project

Topology:



Part 1: Access Control (10 points):

In this part, you will implement simple access control rules using iptables on the Border Router (BR). Specifically, the following requirements must be considered:

1- Devices in the internal network must be able to communicate with the Wide Area Network (WAN).
2- Devices in the internal network must be able to communicate with the Demilitarized Zone (DMZ).
3- Devices in the Wide area network must be able to communicate with devices in the DMZ zone.
4- Devices in the WAN cannot *initiate* connections to devices in the internal network.
5- The IP address 216.0.0.5 must not be able to access the web application residing on the web server.

Part 2: Scanning (10 points):

In this part, you will be using the attacker's machine to discover the devices and the services running in the network. The following requirements must be considered:

1- We would like to know which devices are up and running in the network. The report must include the IP address of the devices.

2- Then, we want to determine the operating system used on the devices.
3- Now we want to know which services are running on the discovered devices. For each service, we would like to know the version of the service that is running.

Part 3: Vulnerability assessment (10 points):

In this part, you will be using the attacker's machine to conduct a vulnerability assessment on the devices and the services running in the network. The following requirements must be considered:

1- The OpenVAS tool must be used for this task.
2- The vulnerability assessment must be conducted on:
    a. Web server
    b. DNS server
    c. Mail server
3- Another vulnerability assessment for the three servers mentioned above must be conducted using the CVE database.
4- A detailed report must be presented. It should be exported as a TXT file.

Part 4: Remote Access Trojan and Backdoor installation (10 points):

In this part, you will be using the attacker's machine to gain access to the victim's machine. The following requirements must be considered:

1- You will generate a malicious payload (`Reverse_TCP Meterpreter`).
2- You create a listener to accept connections from the victim.
3- You will start an HTTP server and copy the malicious file to it.
4- The victim will download that file and execute it. Note that the antivirus must be disabled on the victim for this attack to work.
5- Then, you will delete an arbitrary file on the victim's machine.
6- You must escalate privileges and gain root access to the victim.
7- Then, you must install a backdoor which will allow you to maintain persistent access to the victim's machine.

Part 5: Social Engineering and Spyware (10 points):

In this part, you will be using the attacker's machine to gain access to the victim's machine. The following requirements must be considered:

1- You will send a phishing email that contains a malicious file
2- Once the victim executes the file, you will gain access to their machine.
3- Then, you will install a spyware to monitor the user's behavior. This includes taking a screenshot, activating screenshare, and logging the keys they type on the keyboard.

Part 6: Web-based attacks (10 points):

In this part, you will be using the attacker's machine to access the website hosted on the web server. The following requirement must be considered:

1- You will attempt to perform an SQL injection attack, different than the one shown in the lab in class.

Part 7: DDoS attacks (10 points):

In this part, you will be using the attacker's machine to flood the web server with requests as follows:

1- SYN Flood. Make sure to randomize the source IP of the packets.
2- UDP Flood.
3- FIN Flood.
4- RST Flood.
5- ICMP Flood.

Part 8: Cryptography – Symmetric Encryption (10 points):

In this part, you will be generating a symmetric key used for encrypting data. The following requirements must be considered:

1- The key to be generated must be AES256.
2- You will encrypt any file of your choice using that key.
3- You will decrypt the file using the same key and verify that it matches the original file.
4- You will encrypt using both CBC and EBC modes.

Part 9: Cryptography – Asymmetric Encryption (10 points):

In this part, you will be generating asymmetric keys used for encrypting data. The following requirements must be considered:

1- Generate two RSA 2048-bit public/private key pairs. One for Alice (sender) and one for Bob (receiver).
2- Create a text file that contains the following phrase: "This is the final project for ITEC493"
3- Encrypt the file with the public key of Bob.
4- Decrypt the file with the private key of Bob.
5- Sign the file as Bob and verify Bob's signature.
6- Use Diffie-Hellman (DH) to share a secret between Alice and Bob.

Part 10: Public Key Infrastructure (10 points):

1- In this part, you will become a root Certificate Authority (CA).
2- You will generate a certificate for the domain mycompany.com
3- You will sign the certificate using the CA.
4- Then, you will install it on the Apache web server on the attacker's machine.
5- You should do the necessary configuration so that no warning messages are displayed when visiting the website.

Submission details:

The report should include screenshots and explanations for each step. If you do not include screenshots and explanations, you will get a zero. The explanation should be properly written. Copying and pasting from the labs will not be accepted.